

Ingressa

Venda de ingressos que não vende o mesmo lugar duas vezes

Análise, decisões e evolução: Júnior → Pleno → Sênior

Como ler este documento

Este é um estudo de caso. Ele não descreve só o que o sistema faz: explica **por que** cada decisão foi tomada, o que foi descartado e o que cada versão ensinou. A história segue esta linha:

Eu tinha uma lista de ideias → escolhi uma com um problema real → construí a versão mais simples que funciona (Júnior) → provei onde ela quebra → reorganizei e corriji (Pleno) → planejei como ela aguentaria escala e ataques (Sênior).

Parte	Conteúdo
1. Visão geral	Nome, problema, solução, público e objetivo
2. Análise da ideia	Por que esta ideia, o que havia de errado nela e o que mudou
3. Análise técnica	Stack, arquitetura, banco, API, autenticação, segurança, infraestrutura, testes
4. Versão Júnior	O que foi construído e onde ela quebra
5. Versão Pleno	Como cada limitação foi resolvida
6. Versão Sênior	Plano para escala, resiliência e segurança avançada
7. Decisões arquiteturais	Alternativas, vantagens, desvantagens e trade-offs
8. Roadmap	Do zero à versão avançada
9. Aprendizados	Conhecimentos desenvolvidos em cada etapa
10. Valor para o portfólio	O que o projeto demonstra para um recrutador
Apêndice	Como rodar e como validar

1. Visão geral

Item	Descrição
Nome	Ingressa
Descrição	Plataforma de venda de ingressos para eventos: organizadores cadastram eventos e setores; clientes reservam, pagam e recebem ingressos com código único.
Problema	Vendas concorridas derrubam sites, vendem o mesmo lugar duas vezes, perdem pagamentos no meio do caminho e favorecem robôs.
Solução	Um sistema que trata concorrência, consistência e justiça como requisitos centrais — e que evolui em três versões para mostrar cada técnica sendo introduzida quando passa a ser necessária.
Público-alvo	Produtoras de eventos pequenas e médias (vendedores) e o público que compra ingressos.
Objetivo	Servir de peça principal do portfólio: mostrar fundamentos (Júnior), organização profissional (Pleno) e raciocínio de arquitetura (Sênior) sobre o mesmo domínio.

Por que este problema é bom para aprender

- Qualquer pessoa entende o problema em uma frase ("não vender o mesmo lugar duas vezes").
- Por trás da frase simples existem desafios clássicos de backend: condição de corrida, transações, consistência entre sistemas, filas e picos de acesso.
- É fácil demonstrar o problema e a solução com números — o que torna a evolução verificável, não só descrita.

2. Análise da ideia

Origem

A ideia veio do item 27 da lista "27 projetos para ir de jr a sênior em programação web": *"Sistemas fullstack com filas: sistemas de leilão, sistemas de venda de ingresso. Tente usar filas, microserviços etc."* A análise completa das 27 ideias está no documento 00 da pasta de documentação geral.

Por que esta ideia foi escolhida

Critério	Nota (1-5)	Justificativa
Dificuldade técnica	5	Concorrência, consistência, mensageria, escala
Valor para portfólio	5	Conversa diretamente com vagas de backend .NET
Potencial comercial	3	Mercado com concorrentes fortes (Sympla, Eventim), mas nicho de produtoras pequenas existe
Encaixe com a carreira	5	C#/.NET, SQL, cloud e segurança — as áreas prioritárias

Problemas encontrados na ideia original

Problema	Por que é um problema	Alteração feita
"Tente usar microserviços"	Começar por microserviços troca uma transação simples por uma saga distribuída. É o erro mais comum em projetos de estudo.	Monólito em camadas + Worker separado. Microserviços só na Sênior, e só se uma medição justificar.
Escolher entre leilão e ingressos	Leilão exige tempo real e regras de lance que desviam do foco.	Ingressos: regra simples de explicar, problema muito conhecido no Brasil.
Pagamento real	Exige contrato com gateway e cuidados de PCI DSS.	Gateway simulado com o mesmo contrato de um real (token, aprovação, recusa, estorno).

Problema	Por que é um problema	Alteração feita
Mapa de assentos	Muito trabalho de interface para pouco aprendizado de backend.	Setores com capacidade. Assento numerado fica como evolução.
"Com filas" desde o início	Filas não fazem sentido antes de existir algo assíncrono.	Júnior sem filas; filas entram na Pleno junto com o pagamento e a emissão.

Ideias combinadas

Outras ideias da lista viraram funcionalidades do Ingressa, em vez de projetos separados: **lista, busca, ordenação e paginação** (vitrine), **tela de login/cadastro** (autenticação), **formulários complexos** (cadastro de evento e setores) e **e-commerce** (reserva e pagamento).

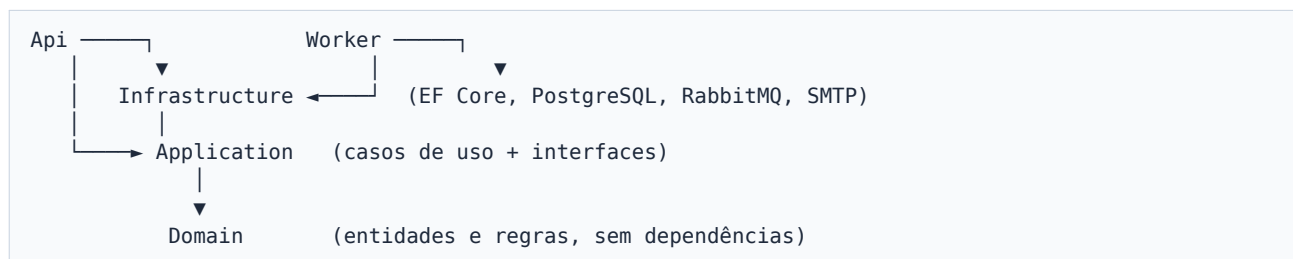
3. Análise técnica

Stack escolhida e justificativa

Tecnologia	Onde	Por quê
C# 14 / .NET 10	Todas as versões	Prioridade de carreira; versão com suporte de longo prazo (LTS); continuidade do projeto helpdesk.
ASP.NET Core (controllers)	API	Organização explícita para quem está começando; atributos de autorização por endpoint; OpenAPI nativo.
Entity Framework Core 10	Dados	ORM padrão do ecossistema; migrations; LINQ traduzido para SQL; ExecuteUpdate para operações atômicas.
SQLite → PostgreSQL 17	Júnior → Pleno	SQLite: zero instalação. PostgreSQL: concorrência real, xmin, índices parciais, SKIP LOCKED, jsonb.
JWT (HS256)	Autenticação	Padrão de mercado para APIs; na Pleno, combinado com refresh token em cookie.
RabbitMQ 4	Pleno	Broker mais usado com .NET; filas quorum, dead letter, publisher confirms.
React 19 + TypeScript	Interface Pleno	Tipagem dos contratos da API; ecossistema mais pedido em vagas full stack.
xUnit, Testcontainers, Vitest	Testes	Padrões do mercado; Testcontainers permite testar contra PostgreSQL real.
Docker Compose, GitHub Actions	Operação	Ambiente reproduzível com um comando; CI gratuito integrado ao GitHub.
Scalar	Documentação	Interface moderna sobre o OpenAPI gerado pelo próprio ASP.NET Core.

Arquitetura

Júnior: um projeto com pastas por responsabilidade (Controllers, Services, Models, Data, Auth, Erros). **Pleno:** camadas com dependências apontando para dentro — Domain não conhece ninguém; Application define interfaces; Infrastructure as implementa; Api e Worker montam tudo.



Banco de dados

Tabela	Papel	Detalhes importantes
Usuarios	Contas	E-mail único; perfil e status como texto; tentativas falhas e bloqueio
RefreshTokens	Sessões	Só o hash SHA-256; família para detectar reuso
Eventos / Setores	Catálogo e estoque	CHECK (Ocupados entre 0 e Capacidade); índice (Publicado, DataInicio)
Pedidos / ItensPedido	Reservas e compras	Preço congelado no item; xmin como versão; índice parcial das reservas pendentes
Ingressos	Entrada no evento	Código único de 64 bits aleatórios
MensagensOutbox	Mensageria confiável	jsonb; índice parcial das pendentes; tentativas e último erro

APIs, autenticação e autorização

- API REST com Problem Details (RFC 9457) para erros: 400 validação, 401 sessão, 403 perfil/dono, 404 inexistente ou alheio, 409 conflito de estado, 422 regra de negócio, 429 excesso de tentativas.
- **Autenticação:** Júnior com JWT de 60 min; Pleno com access token de 15 min em memória e refresh token rotativo em cookie HttpOnly/Secure/SameSite=Strict.
- **Autorização:** por perfil (Cliente, Organizador, Admin) e por propriedade (só o dono altera o evento; pedido de outra pessoa responde 404). Na Pleno, organizadores precisam de aprovação.

Segurança, infraestrutura e testes

Os detalhes estão nas seções de cada versão. Em resumo: hash PBKDF2 com 600 mil iterações, comparação em tempo constante, bloqueio de conta, limite por IP, escape de curingas no ILIKE, cabeçalhos de segurança, CSP, contêineres sem privilégios e nenhum segredo no repositório. A infraestrutura sobe com Docker Compose (PostgreSQL, RabbitMQ, Mailpit, API, Worker, nginx). Os testes vão de unidade (domínio puro) a integração com PostgreSQL real.

4. Versão Júnior — construir o simples, bem feito

Objetivo: provar fundamentos. Uma API correta, organizada, testada e documentada, que qualquer pessoa roda com um comando.

O que foi construído

Área	Entregue
Autenticação	Cadastro e login; PBKDF2 com salt; JWT com emissor, audiência e expiração; aplicação não inicia com chave fraca
Eventos	CRUD com rascunho e publicação; setores com preço e capacidade; só o dono altera; eventos com vendas não são excluídos
Vitrine	Busca, filtro por cidade, ordenação e paginação estável
Compra	Até 6 ingressos; validação de todos os itens antes de alterar; preço congelado; código aleatório; cancelamento até 24 h antes
Erros	Exceções de domínio convertidas em Problem Details em um único lugar
Interface	Vitrine em JavaScript puro com escape de HTML (proteção contra XSS)
Qualidade	54 testes (xUnit) com SQLite em memória real e relógio controlado; 11 commits no padrão Conventional Commits; README com diagramas

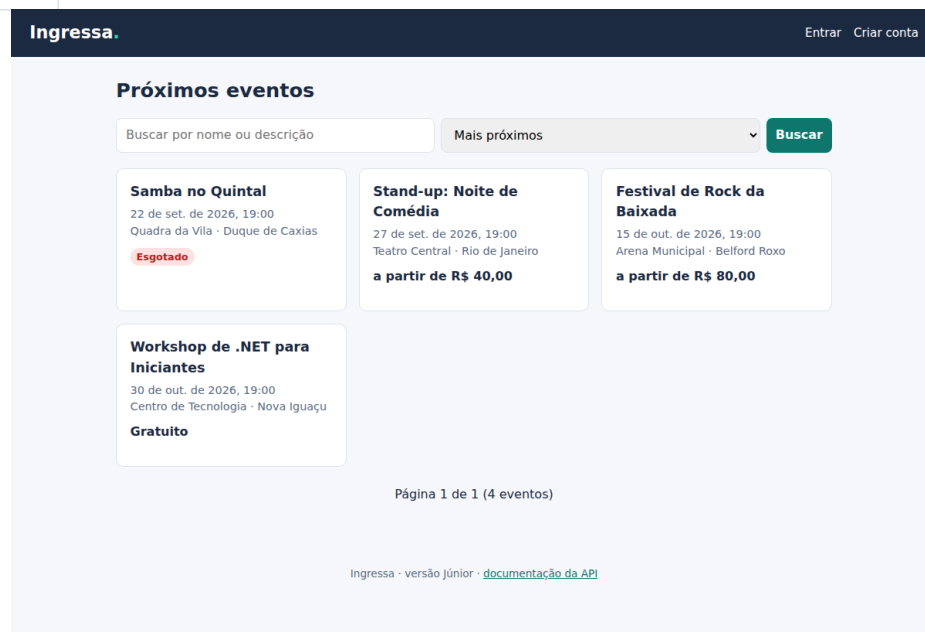


Figura 1 — Vitrine da versão Júnior.

Onde a versão Júnior quebra

A baixa de estoque segue o padrão "ler → calcular → gravar". Para demonstrar o impacto, o mesmo padrão foi executado diretamente no PostgreSQL com 200 compras simultâneas para 10 lugares:

Método	Compras aceitas	Lugares registrados	Resultado
Júnior: ler → calcular → gravar	200	9	190 ingressos vendidos sem lugar; contador errado
Pleno: UPDATE condicional	10	10	Correto

A limitação foi mantida de propósito e documentada no código e no README. Ela é o motivo da versão Pleno existir. Outras limitações: compra sem reserva nem pagamento, tudo em um

projeto, token sem renovação, qualquer pessoa se cadastrando como organizador, esquema criado sem migrations, e ausência de Docker e CI.

5. Versão Pleno — estruturar como um sistema profissional

Objetivo: resolver cada limitação da Júnior com a técnica adequada — e não adicionar nada sem motivo.

Limitação	Solução	Por que esta e não outra
Venda duplicada	UPDATE atômico condicional + CHECK no banco	Não segura travas; nenhuma tentativa válida precisa ser repetida (ADR 0005)
Pagar e expirar ao mesmo tempo	Concorrência otimista com xmin	Conflito raro: melhor detectar do que travar
Sem reserva/pagamento	Reserva de 10 min, gateway simulado, expiração em lote, estorno automático	Modelo usado pelas grandes plataformas
Mensagem perdida se o processo cair	Transactional Outbox + RabbitMQ	Elimina a escrita dupla (ADR 0006)
Tudo em um projeto	Camadas + Worker	Domínio testável sem banco; transação única preservada (ADR 0004)
Token exposto e irrevogável	Refresh token rotativo em cookie HttpOnly, com detecção de reuso	Recomendação do OAuth 2.0 Security BCP (ADR 0007)
Força bruta	Bloqueio de conta + limite por IP	Duas camadas: por conta e por origem
Organizadores falsos	Aprovação por administrador	Quem vende responde pelo evento
EnsureCreated / SQLite	PostgreSQL + migrations + checagem no CI	Esquema versionado e revisável
Sem operação	Docker Compose, CI, logs JSON correlacionados, health checks	Ambiente idêntico para qualquer pessoa

O fluxo de uma compra

```

Cliente —POST /pedidos→ API —BEGIN
    UPDATE Setores SET Ocupados = Ocupados + n
    WHERE Id = @s AND Capacidade - Ocupados >= n    (por setor)
    INSERT Pedido (AguardandoPagamento, expira em 10 min)
    COMMIT → 201
Cliente —POST /pagamento→ API → gateway (fora da transação)
    UPDATE Pedido ... WHERE xmin = @versao + INSERT outbox "pedido.pago"
"
Worker —SELECT outbox FOR UPDATE SKIP LOCKED→ publica no RabbitMQ (com confirmação)
Worker ← "pedido.pago" — emite ingressos (idempotente) + outbox "ingressos.emitidos"
Worker ← "ingressos.emitidos" — envia e-mail com os códigos
Worker (a cada 30 s) — reservas vencidas ► Expirado + devolve os lugares
  
```

Figura 2 — Pagamento recusado; a reserva continua valendo.

Setor	Código do ingresso	Valor
Pista	1A1908C3AE60000	R\$ 80,00
Pista	E25403AB23EB2000	R\$ 80,00
Pista Premium	874604FE16E71000	R\$ 150,00
Total: R\$ 310,00		

Figura 3 — Ingressos emitidos pelo Worker.

Casos difíceis tratados

- **Reserva expira enquanto o gateway processa:** o pagamento foi aprovado, mas o pedido já não pode ser pago. O valor é estornado automaticamente e o cliente recebe 422.
- **Um setor do pedido não tem lugar:** a transação inteira é desfeita, inclusive os setores que já tinham sido ocupados.
- **Mensagem entregue duas vezes:** a emissão verifica se já emitiu; a segunda entrega não faz nada.
- **Mensagem que sempre falha:** após 5 entregas vai para a fila de falhas, sem travar as demais.
- **Refresh token copiado por um atacante:** quando o token já usado reaparece, toda a família de tokens é revogada.
- **Usuário digita % na busca:** o curinga é escapado; a busca procura o caractere literal.

Estratégia de testes

Nível	Quantidade	Ferramenta	O que garante
Domínio	43	xUnit	Regras e máquina de estados, sem banco
Casos de uso	34	xUnit + adaptadores em memória	Orquestração, rollback, 50 reservas paralelas, estorno, rotação de sessão
Integração	15	WebApplicationFactory + Testcontainers	API real contra PostgreSQL real: 40 clientes x 5 lugares, xmin, cookies, 429
Interface	11	Vitest + Testing Library	Renovação automática e única da sessão, mensagens de erro, vitrine

O que foi deixado de fora de propósito

MediatR, AutoMapper, Redis, ASP.NET Core Identity e microserviços foram avaliados e não entraram: com o tamanho atual, cada um acrescentaria complexidade sem resolver um problema existente. A justificativa de cada um está no README da versão Pleno.

6. Versão Sênior — escala, resiliência e segurança (planejada)

Situação: esta seção é o plano da próxima etapa. As decisões abaixo serão confirmadas ou revistas com base em medições (testes de carga) antes de serem implementadas.

Limitações da Plano que motivam a Sênior

Limitação	Plano	Como será validado
Pico de 100 mil acessos às 10h derruba a API	Fila virtual (sala de espera) com Redis: o usuário recebe uma posição e só entra na compra quando chega a vez	k6 simulando pico; meta de latência p95 e zero erro 5xx
Robôs distribuídos	Limites por usuário e por evento, token de acesso à fila, sinais de abuso	Testes automatizados de abuso
Clique duplo cobra duas vezes (e estorna)	Chave de idempotência por requisição	Teste de integração com requisições repetidas
Sem métricas nem tracing	OpenTelemetry: traces API → outbox → RabbitMQ → Worker; métricas de negócio (reservas, expirações)	Painéis e alertas
Sem nuvem	Terraform na AWS (ECS Fargate, RDS PostgreSQL, Amazon MQ, ElastiCache), segredos no Secrets Manager	Ambiente criado e destruído por pipeline
Sem plano de desastre	Backups automáticos, restauração testada, runbooks	Exercício de restauração documentado
Segurança só em testes manuais	SAST (CodeQL), análise de dependências, DAST (OWASP ZAP) no CI, modelagem de ameaças STRIDE	Pipeline bloqueando vulnerabilidades altas
Interface sem testes ponta a ponta	Playwright no CI	Fluxo completo de compra automatizado

Microsserviços: a decisão será medida

A hipótese mais provável é extrair apenas a **fila virtual**, porque ela tem um perfil de carga completamente diferente (milhares de conexões esperando, pouca escrita) e pode ser escalada sozinha. Catálogo e pedidos continuam juntos para preservar a transação da compra. Se o teste de carga mostrar que o monólito escalado horizontalmente atende à meta, nenhuma extração será feita — e essa conclusão também será registrada em um ADR.

7. Decisões arquiteturais

Cada decisão tem um registro próprio (ADR) no repositório. O resumo:

Decisão	Alternativas consideradas	Vantagens	Desvantagens / trade-off
Monólito simples na Júnior (ADR 0001)	Clean Architecture desde o início; microsserviços	Fácil de ler; um comando para rodar	Disciplina depende de convenção
SQLite na Júnior (ADR 0002)	PostgreSQL; LocalDB	Zero instalação	Esconde concorrência; não agrega decimal
JWT próprio (ADR 0003)	ASP.NET Identity; Auth0/Keycloak	Mecanismo visível e testado	Recursos extras precisam ser construídos
Camadas + Worker, sem microsserviços (ADR 0004)	Microsserviços; manter um projeto	Transação única; domínio testável	Mais projetos; banco compartilhado
UPDATE atômico para estoque (ADR 0005)	Lock pessimista; otimista no setor; lock no Redis	Correto sem travas longas	Não serve para assento numerado
Outbox + RabbitMQ (ADR 0006)	Processar na requisição; fila em memória; publicar após commit; outbox sem broker	Nenhuma mensagem perdida; filas de falha	Entrega "pelo menos uma vez"; mais um serviço
Refresh token em cookie (ADR 0007)	JWT longo no localStorage; sessão no servidor; BFF	Resistente a XSS; revogável	Exige mesma origem e lógica de renovação
Repositórios + consultas (ADR 0008)	DbContext na Application; repositório genérico	Application sem EF; leituras eficientes	Mais interfaces

8. Roadmap

Etapas	Entregas	Status
0. Análise	Avaliação das 27 ideias; escolha e ajuste do problema	Concluída
1. Júnior	API, autenticação, CRUD, vitrine, compra, testes, interface simples	Concluída
2. Pleno	Camadas, PostgreSQL, concorrência, reserva e pagamento, outbox, RabbitMQ, sessão segura, React, Docker, CI	Concluída (validação final no ambiente local)
3. Sênior — medir	Testes de carga com k6 e metas (SLOs) sobre a Pleno	Planejada
4. Sênior — escalar	Fila virtual, idempotência, limites por usuário, cache onde a medição indicar	Planejada
5. Sênior — operar	OpenTelemetry, Terraform/AWS, backups, runbooks, segurança no CI	Planejada

9. Aprendizados

Versão	Conhecimentos desenvolvidos
Júnior	Modelagem relacional com EF Core; API REST e códigos HTTP; validação; tratamento centralizado de erros; hash de senha; JWT; testes com banco em memória; TimeProvider; Git com commits semânticos; documentação
Pleno	Arquitetura em camadas e inversão de dependência; domínio rico; transações e níveis de consistência; condição de corrida e concorrência otimista; PostgreSQL (xmin, índices parciais, SKIP LOCKED, CHECK); mensageria (exchanges, filas quorum, dead letter, confirmações, idempotência); padrão Outbox; sessão segura (cookies, CSRF, XSS, rotação); limite de requisições; Docker multi-stage; CI; Testcontainers; React e TypeScript
Sênior (plano)	Testes de carga e SLOs; filas virtuais; observabilidade com OpenTelemetry; infraestrutura como código; segurança no pipeline; recuperação de desastre; decisão baseada em medição

10. Valor para o portfólio

O que um recrutador técnico consegue verificar no repositório:

Competência	Evidência
Constrói uma API completa	Versão Júnior rodando com um comando; 16 endpoints documentados
Escreve código testável	157 testes em quatro níveis; testes contra PostgreSQL real
Entende concorrência	Experimento reproduzível (200 × 10) e teste com 40 clientes HTTP
Pensa em falhas	Outbox, idempotência, estorno automático, dead letter, expiração
Pensa em segurança	Sessão resistente a XSS/CSRF, detecção de token roubado, bloqueio, limites, CSP
Toma decisões e explica	8 ADRs com alternativas e trade-offs; lista do que não foi usado e por quê
Trabalha como em uma empresa	Conventional Commits, CI, Docker, README por versão, migrations verificadas
Consegue evoluir um sistema	Três versões no mesmo repositório, cada uma motivada pelas limitações da anterior

Pergunta de entrevista que este projeto responde bem: "Como você evitaria vender o mesmo ingresso duas vezes?" — com a resposta errada (Júnior), a prova de que ela é errada (experimento) e a resposta certa (Pleno), cada uma com código e teste.

Apêndice — como rodar e validar

Versão Júnior

```
cd ingressa/junior
dotnet test
dotnet run --project src/Ingressa.Api --launch-profile http
# http://localhost:5080 · cliente@ingressa.dev / Senha@123
```

Versão Pleno

```
cd ingressa/pleno
docker compose up --build
# interface: http://localhost:8080   API: http://localhost:5180/scalar
# RabbitMQ: http://localhost:15672   e-mails: http://localhost:8025

dotnet test          # Docker aberto (testes de integração)
cd web && npm test
```

Nota sobre o processo de validação

O código foi escrito e revisado em um ambiente sem acesso ao repositório de pacotes .NET (NuGet). Para não depender apenas de revisão, as regras de domínio e os casos de uso foram compilados e executados ali com implementações mínimas das bibliotecas, o experimento de concorrência foi executado em um PostgreSQL 16 real, e a interface foi testada em um navegador automatizado (Playwright). A compilação com os pacotes oficiais, a geração da migration inicial e os testes de integração com Testcontainers são executados no computador de desenvolvimento e no CI do GitHub.